

Vulnerability Assessment and Threat Intelligence

Ryan Dooley

Qualys Cloud Agent

May 4th, 2025

Table of Contents

<u>Section</u>	<u>Page #</u>
1.0 Summary.....	3
2.0 Risk Assessment.....	3
2.1 Severity Five.....	3
2.2 Severity Four.....	5
2.3 Severity Three.....	8
3.0 Remediation.....	11
4.0 Threat Intelligence.....	12

1.0 Summary

This vulnerability scan aims to gain experience working with cloud agents such as Qualys and practicing vulnerability remediation. Over thirty-four vulnerabilities were confirmed on my Personal Computer, and this report will cover each and their remediations.

2.0 Risk Assessment

Below are the results of the vulnerability scan:

Severity Five	Severity Four	Severity Three	Severity Two	Severity One
5	18	11	0	0

2.1 Severity Five

Five of the thirty-four vulnerabilities were severity five, the highest severity. These vulnerabilities proved to be the most threatening to my computer and were my highest priority to fix.

Vulnerability	Threat Description	Solution	Count
EOL/Obsolete Software: Microsoft .NET Version 6 Detected	.NET Core is a modular, cross-platform, and open source software development framework that is used to build Windows, Web, and Mobile applications for Windows, Linux and OS X platforms. Technical support and servicing updates for Microsoft .Net Core Version 6 will end on Nov 12, 2024.	Remove any old versions of Microsoft .NET Version 6	1
VMware Workstation Multiple Security Vulnerabilities (VMSA-2025-0004)	VMware Workstation is a hosted hypervisor that runs on x64 versions of Windows and Linux operating systems. Affected Versions:	Update VMware Workstation to the newest version	1

	VMware Workstation Pro / Player (Workstation) 17.x series prior to 17.6.3		
Microsoft .NET Core Security Update for January 2024	Microsoft has released January 2024 security updates for .NET Core to fix multiple security vulnerabilities. Affected versions: .NET 6.0 before version 6.0.26 .NET 7.0 before version 7.0.15 .NET 8.0 before version 8.0.1	Download the newest version of Microsoft .NET and remove older versions that aren't used	1
Oracle Java Standard Edition (SE) Critical Patch Update - April 2025 (CPUAPR2025)	Oracle Java Runtime Environment (JRE) is a platform that supports the execution of programs that are developed using the Java programming language. The JRE platform also supports Java Applets, which can be loaded from web pages. This Critical Patch Update contains 6 new security patches for Oracle Java SE. 5 of these vulnerabilities may be remotely exploitable without authentication, i.e., may be exploited over a network without requiring user credentials. Oracle Java JRE and JDK contain multiple remotely exploitable vulnerabilities that affect various components. Affected Versions: Oracle Java SE : Oracle Java SE, versions 8u441, 8u441-perf, 11.0.26, 17.0.14, 21.0.6, 24 and prior	Update Java to the newest version	1
EOL/Obsolete Software: Microsoft .Net Core Version 7 Detected	.NET Core is a modular, cross-platform, and open source software development framework that is used to build Windows, Web, and Mobile applications for Windows, Linux and OS X	Remove any old versions of Microsoft .NET Version 7	1

	platforms. Technical support and servicing updates for Microsoft .Net Core Version 7 will end on May 14, 2024.		
--	---	--	--

2.2 Severity Four

Eighteen of the thirty-four vulnerabilities were severity four, the second-highest severity. While these vulnerabilities were technically different, some were related to the same problem source. As such, I have grouped them in the table to make it easier to read.

Vulnerability	Threat Description	Solution	Count
Microsoft .NET Security Update for January 2025	Microsoft has released a security update for .NET that addresses vulnerabilities related to Information Disclosure, and Denial of Service. Affected versions: - .NET 9.0 before version 9.0.1 - .NET 8.0 before version 8.0.12	Download the newest version of Microsoft .NET and remove older versions	12
Oracle Managed Virtualization (VM) VirtualBox Multiple Security Vulnerabilities (CPUAPR2025)	Oracle VM VirtualBox is an x86 virtualization software package. Vulnerability in the Oracle VM VirtualBox component of Oracle Virtualization (subcomponent: Core) Affected Versions: Oracle VM VirtualBox versions upto 7.1.6	Update Oracle VM VirtualBox to the latest release version	2
Microsoft WinVerifyTrust Signature Validation Vulnerability	Microsoft stated that they have re-published the CVE-2013-3900 to inform customers about the availability of EnableCertPaddingCheck. This behavior remains available as an opt-in feature via the registry key	Enable signature checking by enabling EnableCertPaddingCheck within the Software and Wow6432Node folders via the registry editor	1

	setting and is available on all supported editions of Windows released since December 10, 2013. Microsoft recommends that executable authors consider conforming all signed binaries to the new verification standard by ensuring that they contain no extraneous information in the WIN_CERTIFICATE structure. Microsoft also recommends that customers appropriately test this change to evaluate how it will behave in their environments. Microsoft recommends that customers test how this change to Authenticode signature verification behaves in their environment before fully implementing it. To enable the Authenticode signature verification improvements, modify the registry to add the EnableCertPaddingCheck value as detailed below. - HKEY_LOCAL_MACHINE\Software\Microsoft\Cryptography\Wintrust\Config "EnableCertPaddingCheck"="1" - HKEY_LOCAL_MACHINE\Software\Wow6432Node\Microsoft\Cryptography\Wintrust\Config "EnableCertPaddingCheck"="1"		
Microsoft HTTP/2 Protocol Distributed Denial of Service (DoS) Vulnerability	CVE-2023-44487: The HTTP/2 protocol is vulnerable to Distributed Denial of Service (DDoS) attack also known as 'HTTP/2 Rapid Reset' attack. This allows malicious actors to launch a DDoS attack targeting HTTP/2 servers. Affected Products: Windows Server 2019	Disable the HTTP/2 protocol by setting EnableHttp2 to zero via the registry editor	1

	Windows Server 2016 Windows Server 2022 Windows 11 Version 21H2 Windows 11 Version 22H2 Windows 10 Version 21H2 Windows 10 Version 22H2 Windows 10 Version 1607 Microsoft Windows 10 Version 1809 .NET 7.0 and 6.0 ASP.NET Core 7.0 and 6.0 Microsoft Visual Studio 2022 version 17.2 Microsoft Visual Studio 2022 version 17.4 Microsoft Visual Studio 2022 version 17.6 Microsoft Visual Studio 2022 version 17.7		
Google Chrome Prior to 136.0.7103.59 (Linux) and 136.0.7103.48/49 (Windows/MacOS) Multiple Vulnerabilities	Chrome has released security updates for Windows, Mac, and Linux to fix the vulnerabilities. Note: The preceding description block is extracted directly from the security advisory. Using automation, we have attempted to clean and format it as much as possible without introducing additional issues. Affected Versions: Google Chrome Versions Prior to 136.0.7103.59 (Linux) and 136.0.7103.48/49 (Windows/MacOS)	Update Google Chrome to the newest version	1
Wireshark Bundle Protocol and CBOR dissector crash Vulnerability (wnpa-sec-2025-01)	Wireshark is a network protocol analyzer available for multiple operating systems. It lets you capture and interactively browse the traffic running on a computer network. The Bundle Protocol and CBOR dissectors could crash. Fixed in master: 83c73a83ad Fixed in release-4.4: 73d7d46bcc Fixed in release-4.2: 2e5e8c1d9a	Update Wireshark to the newest version	1

	Affected version: Wireshark version: 4.4.0 to 4.4.3, 4.2.0 to 4.2.10 Note: The preceding description block is extracted directly from the security advisory. Using automation, we have attempted to clean and format it as much as possible without introducing additional issues.		
--	---	--	--

2.3 Severity Three

Eleven of the thirty-four vulnerabilities were severity three, the third-highest severity. Similar to the vulnerabilities in severity four, some were related to the same problem source. As such, I have grouped them in the table to make it easier to read.

Vulnerability	Threat Description	Solution	Count
Microsoft .NET Security Update for August 2023	Microsoft has released a security Update for .NET which resolves Information Disclosure, Remote Code Execution, and Denial of Service vulnerabilities. Affected versions: .NET 6.0 before version 6.0.21 .NET 7.0 before version 7.0.10	Download the newest version of Microsoft .NET and remove older versions	6
Built-in Guest Account Not Renamed at Windows Target System	The built-in Guest account is not renamed at the target Microsoft Windows system.	Rename the guest account	1
SMB Signing Disabled or SMB Signing Not Required	This host does not seem to be using SMB (Server Message Block) signing. SMB signing is a security mechanism in the SMB protocol and is also known as security signatures. SMB signing is designed to help improve the security of the SMB	Enable SMB signing by changing the "Digitally sign communications" setting to always via Group Policy	1

	protocol. SMB signing adds security to a network using NetBIOS, avoiding man-in-the-middle attacks. When SMB signing is enabled on both the client and server SMB sessions are authenticated between the machines on a packet by packet basis.		
Microsoft Windows Secure Kernel Mode Elevation of Privilege Vulnerability	An elevation of privilege vulnerability exists in Windows based systems supporting Virtualization Based Security (VBS) including a subset of Azure Virtual Machine SKUS; enabling an attacker with administrator privileges to replace current versions of Windows system files with outdated versions. Affected version: All Operating Systems mentioned in CVE-2024-21302 An elevation of privilege vulnerability exists in Windows based systems supporting Virtualization Based Security (VBS) including a subset of Azure Virtual Machine SKUS; enabling an attacker with administrator privileges to replace current versions of Windows system files with outdated versions. Affected Products: All Operating Systems mentioned in CVE-2024-21302.	Ensure the latest Windows Security update is installed, enable VirtualizationBasedSecurityStatus in the registry editor, and enable UserModeCodeIntegrityPolicyEnforcementStatus via PowerShell	1
Windows Unquoted/Trusted Service Paths Privilege Escalation Security Issue	There exists a security issue with Windows when handling the paths of services running on the system. When the service path is a long name and contains a space and not quoted, the file name becomes ambiguous. For	Properly quote each Windows service path via PowerShell	1

	example, consider the string "c:\program files\sub dir\program name". This string can be interpreted in a number of ways. The system tries to interpret the possibilities in the following order: c:\program.exe files\sub dir\program name c:\program files\sub.exe dir\program name c:\program files\sub dir\program.exe name If an attacker is able to place a malicious executable in one of these unexpected paths, sometimes escalate privileges if run as SYSTEM. Further details about the vulnerability can be found at Exploit DB #20543		
Allowed Null Session	It is possible to log into the target host using a NULL session. Windows NT has a feature allowing anonymous users to obtain domain user names and the share list. Windows NT ACL editor requires the Domain Controllers to return a list of account names. We check for "HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Control\LSA\RestrictAnonymous" as well as "HKLM\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters\RestrictNullSessAccess" = 0 as Microsoft has stated that "Remote access to the registry may still be possible after you follow the steps in this article if the RestrictNullSessAccess registry value has been created and is set to 0.	Restrict Null access by enabling RestrictAnonymous and RestrictNullSessAccess via the registry editor	1

	This value allows remote access to the registry by using a null session. The value overrides other explicit restrictive settings."		
--	--	--	--

3.0 Remediation

Following the results of the vulnerability scan, I was able to remediate all of the vulnerabilities. Most were pretty simple, such as updating software and/or removing outdated software, such as the older versions of Microsoft .NET. Some vulnerabilities required editing values in the registry editor or group policy. Thankfully, Qualys outlines the detection logic for their vulnerabilities, making locating the values that need to change easier. I scanned the PC again to ensure I had successfully remediated everything and found no vulnerabilities.

Summary of Vulnerabilities after Remediation:

Severity	Before	After
Five	5	0
Four	18	0
Three	11	0

4.0 Threat Intelligence

After remediating the vulnerabilities identified during my assessment, I conducted threat intelligence research to gain deeper context into some of the issues found on my system. Most of the vulnerabilities I discovered were related to outdated versions of Microsoft .NET, so I selected one of the more recent and relevant issues for further analysis.

Using the Qualys Knowledge Base and linked Microsoft documentation, I focused on the Microsoft .NET Core Security Update for January 2024, which addresses the following CVEs:

- CVE-2024-0057 - Security Feature Bypass
- CVE-2024-20672 - Denial of Service
- CVE-2024-21319 - Denial of Service

According to Microsoft, these vulnerabilities affect .NET Core runtime components and could allow attackers to disrupt service availability or bypass certain built-in security features under specific conditions. In line with Microsoft's coordinated disclosure policy, these vulnerabilities were not publicly disclosed until the patch release. As a result, there are no confirmed public exploitations in the wild at the time of this report.

This research reinforced the importance of timely patching, even for vulnerabilities without known public exploitation.

Sources:

- CVE-2024-0057:
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-0057>
- CVE-2024-20672:
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-20672>
- CVE-2024-21319:
<https://msrc.microsoft.com/update-guide/vulnerability/CVE-2024-21319>
- Qualys Knowledge Base